Saudi GRC Platform

Workflow Lifecycles

Source: `workflow-lifecycles.md`

08 — Workflow Status Lifecycles

Per-workflow state machines. Drawn from the actual service classes that enforce transitions. All transitions write to `audit.events` and emit a `changed.{entity}` realtime broadcast.

Shared notation: - → = allowed transition. - Italic role = the only role(s) authorised to move the record. - ■ = SLA timer starts on entry to this state. - ■ = notification fires on entry. - ■ = digital signature required to enter.

ERM — Risk lifecycle

Status	Meaning	→ next	Mover	SLA	Notifications	Audit
DRAFT	Identified, not yet assessed	ASSESSED	Risk Owner	none	■ owner	full
ASSESSED	Likelihood × impact scored	APPROVED, DRAFT	Risk Mgr	14d ■	■ Risk Mgr	full
APPROVED	Inherent + residual approved	TREATED, ACCEPTED, MITIGATED, CLOSED	Risk Mgr	none	■ owner	full
TREATED	Treatment plan in flight	MITIGATED, ACCEPTED, CLOSED	Risk Owner	tracked via CAPA	■ monthly	full
ACCEPTED	Above-appetite, formally accepted	MITIGATED, EXPIRED	CRO ■	until expiry	■ CRO + Risk Committee	full
MITIGATED	Residual back below appetite	CLOSED	Risk Mgr	none	■ owner	full
CLOSED	No longer applicable	(terminal)	Risk Mgr	n/a	■ owner	full
EXPIRED	Acceptance lapsed	ACCEPTED, MITIGATED	Risk Mgr	reopen 7d ■	■ CRO	full

ERM — Scenario lifecycle (V35)

`DRAFT → APPROVED → ARCHIVED` (with `REJECTED` side-branch). *Mover:* Risk Mgr. ■ at APPROVED.

ERM — Emerging Risk lifecycle (V39)

`HORIZON → MONITORING → ESCALATED → MATURED | DISMISSED`. *Mover:* Risk Analyst.

ERM — Risk Acceptance lifecycle

`REQUESTED → APPROVED → ACTIVE → EXPIRED → REOPENED`. ■ at APPROVED (CRO).

BCM — BIA lifecycle

`DRAFT → SCORING → IN_REVIEW → APPROVED → SUPERSEDED`. *Mover:* BIA Owner → BCM Manager. SLA 21d from initiation. ■ at APPROVED.

BCM — BCP lifecycle

`DRAFT → IN_REVIEW → APPROVED → ACTIVE → ARCHIVED`. *Mover:* BCM Manager. ■ at APPROVED.

BCM — DRP lifecycle (V41)

Status	Meaning	→ next	Mover	SLA
DRAFT	New plan	IN_REVIEW, REJECTED	DR Owner	7d
IN_REVIEW	Peer review	APPROVED, REJECTED, DRAFT	CIO	7d
APPROVED ■	Operational	ACTIVATED, ARCHIVED	CIO + BCM Mgr	annual test
ACTIVATED	Live failover	APPROVED, ARCHIVED	BCM Mgr	n/a
ARCHIVED	Replaced	(terminal)	BCM Mgr	n/a
REJECTED	Not approved	DRAFT	Reviewer	n/a

BCM — Crisis Event lifecycle

`DECLARED → STAND_UP → ACTIVE → STAND_DOWN → POST_MORTEM`. *Mover:* Crisis Manager. ■ at POST_MORTEM.

BCM — Exercise lifecycle

`SCHEDULED → IN_PROGRESS → COMPLETED → APPROVED`. *Mover:* Exercise Facilitator → BCM Manager.

SCM — Vendor lifecycle

`DRAFT → KYC_PENDING → ACTIVE → SUSPENDED → CLOSED`. *Mover:* Procurement + Supplier Mgr.

SCM — Alternate Supplier lifecycle (V36)

`DRAFT → APPROVED → ARCHIVED`. *Mover:* Vendor Risk Mgr.

SCM — Exit Plan lifecycle (V36)

`DRAFT → APPROVED → ACTIVATED → ARCHIVED` (with `REJECTED`). *Mover:* COO. ■ at APPROVED.

SCM — Supplier Resilience Test lifecycle (V54)

Status	Meaning	→ next	Mover	Auto-action
SCHEDULED	Planned	IN_PROGRESS, CANCELLED	Facilitator	—
IN_PROGRESS	Test running	COMPLETED, CANCELLED	Facilitator	—
COMPLETED	Outcome recorded	APPROVED	BCM/CIO	auto-CAPA on FAIL
APPROVED	Closed	(terminal)	BCM Manager	—

Status	Meaning	→ next	Mover	Auto-action
CANCELLED	Cancelled with reason	(terminal)	Facilitator	—

SCM — Fourth-Party Exposure lifecycle (V50)

`DISCOVERED → VALIDATED → MITIGATED → RETIRED`. *Mover:* Vendor Risk Mgr. **Auto-CAPA** when concentration newly elevates to HIGH.

SCM — Contract Clause lifecycle (V45)

`DRAFT → APPROVED → DEPRECATED`. *Mover:* GC.

Cyber — Cyber Incident lifecycle (NIST 800-61, 9 phases)

`DETECTION → ANALYSIS → CONTAINMENT → ERADICATION → RECOVERY → POST_INCIDENT → LESSONS_LEARNED → CLOSED`. *Mover:* Incident Manager → CISO at LESSONS_LEARNED. ■ at NOTIFIED (NCA / SDAIA).

Cyber — Control Assessment lifecycle

`DRAFT → ASSESSED → APPROVED`. *Mover:* Control Owner → Compliance.

Cyber — Vulnerability lifecycle

`OPEN → IN_REMEDIATION → REMEDIATED → VERIFIED → CLOSED` (with `RISK_ACCEPTED` side-branch). *Mover:* Vulnerability Manager.

Cyber — RCA lifecycle (V31)

`DRAFT → IN_REVIEW → APPROVED → REJECTED`. *Mover:* RCA Facilitator → Approver. ■ at APPROVED. Generates CAPAs on APPROVED.

PDPL — Privacy Notice lifecycle (V32)

`DRAFT → PUBLISHED → ARCHIVED → SUPERSEDED`. *Mover:* DPO. ■ at PUBLISHED.

PDPL — DSR lifecycle

Status	Meaning	→ next	SLA
NEW	Received	IN_REVIEW	day-0
IN_REVIEW	Triage	FULFILLED, REJECTED	day-7 ■
FULFILLED ■	Responded	(terminal)	day-30 hard SLA
REJECTED	Not actionable	(terminal)	with reason
EXPIRED	Missed 30d	escalate to Privacy Mgr	auto-escalate

PDPL — PIA lifecycle

`DRAFT → IN_REVIEW → APPROVED → REJECTED`. *Mover:* DPO. ■ at APPROVED.

PDPL — Breach lifecycle

`DETECTED → CONTAINED → ASSESSED → NOTIFIED → CLOSED`. ■ at NOTIFIED. 72h ■ from DETECTED to NOTIFIED.

PDPL — Cross-Border Transfer lifecycle (V32)

`REQUESTED → ASSESSED → APPROVED / REJECTED → EXPIRED`. *Mover:* DPO.

PDPL — Disposal Certificate lifecycle (V32)

`SCHEDULED → IN_PROGRESS → COMPLETED → VERIFIED → CANCELLED`. *Mover:* Data Owner → DPO. ■ at VERIFIED.

PDPL — Data Sharing Agreement lifecycle (V51)

`DRAFT → IN_REVIEW → ACTIVE → EXPIRED | TERMINATED`. *Mover:* GC + DPO. ■ at ACTIVE.

PDPL — Processor Assessment lifecycle (V52)

`IN_PROGRESS → COMPLETED → APPROVED | REJECTED`. *Mover:* DPO. ■ at APPROVED. **Auto-CAPA on FAIL**.

TPRM — Third-Party Cyber Assessment lifecycle (V53)

`DRAFT → IN_REVIEW → APPROVED → RETIRED`. *Mover:* Vendor Risk Mgr → CISO.

Compliance — Policy lifecycle

`DRAFT → APPROVED → ACTIVE → SUPERSEDED → ARCHIVED`. ■ at APPROVED.

Compliance — Regulatory Change lifecycle

`CAPTURED → IMPACT_ASSESSED → ACTION_PLANNED → IMPLEMENTED → VERIFIED`.

Compliance — Attestation Campaign lifecycle

`SCHEDULED → IN_PROGRESS → CLOSED`.

CAPA lifecycle

`OPEN → IN_PROGRESS → AWAITING_VERIFICATION → CLOSED | CANCELLED`. ■ at CLOSED for high-severity items.

Digital Signature Transaction lifecycle

`REQUESTED → SIGNED | REJECTED | EXPIRED`. *Mover:* Signer.

Committee Meeting lifecycle (V40)

`SCHEDULED → IN_PROGRESS → COMPLETED → MINUTES_APPROVED | CANCELLED`. ■ at MINUTES_APPROVED.

Evidence-item lifecycle

`UPLOADED → REVIEWED → APPROVED → EXPIRED | SUPERSEDED`. Chain verification is event-driven; on `verifyChain()` the chain status flips between `UNVERIFIED → VALID | BROKEN`.

Common SLA rules

Workflow	SLA timer	Hard deadline	Auto-escalation
DSR	30 days	yes (PDPL)	day-23 to DPO, day-28 to Privacy Mgr
Breach notification	72 hours	yes (PDPL Art. 20)	hour-48 to DPO, hour-60 to CISO
BIA cycle	21 days	soft	day-18 to BCM Mgr
DR test	12 months	soft	-30d to DR Owner
Risk acceptance review	annual	soft	-30d to Risk Owner
Processor reassessment	12 months	soft	-30d to DPO
Resilience test	12 months (per vendor tier)	soft	-30d to Vendor Risk Mgr
NCA filing	annual	yes (NCA)	-60d to CISO
Vulnerability patch	30 days (critical)	yes	per-day to Vuln Mgr
CAPA target	per record	tracking	-7d to owner

Common audit-log rules

Every state transition writes a row to `audit.events` containing: - `actor_user_id` + IP + UA - `entity_type` + `entity_id` + `external_id` - `verb` (e.g. `submit`, `approve`, `reject`, `sign`) - `before_json` + `after_json` (status fields only — not full record) - `at` (UTC timestamp).

Audit-log retention: 60 months minimum. Read access restricted to roles with `AUDIT_READ` permission.